Fabrikam Lettings Ltd

Microsoft 365 tenant review: summary and action plan

TENANT
Fabrikam Lettings Ltd

PRIMARY DOMAIN
fabrikam.example

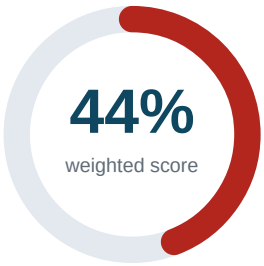
TENANT ID
c0ffee00-1111-2222-3333-444455556666

REVIEW DATE
19/10/2026

REVIEWED BY
Review Engineer (engineer@reviewer.example)

REPORT VERSION
Tool v1.5.0

1. Executive summary



Red

112 checks assessed: 15 pass, 77 warning, 20 fail

25
Licensed users
Enabled, licensed members

88%
MFA capable
22 of 25 users

5
Global admins
Recommended 2 to 4

3
Guests
External accounts

25
Mailboxes
2 shared

10
Intune devices
1 non-compliant

4
Defender devices
2 discovered, not onboarded

48.8%
Secure Score
312 of 640 points

5
Spare licences
Paid, unassigned

7
Unused licensed features
11 more partly used

22%
CIS v7.0.0
29 of 130 assessed controls met

26%
CISA SCuBA
24 of 92 assessed controls met

26%
Azure score
9 fail, 18 warning (see Azure)

10%
Server score
21 fail, 7 warning (see Servers)

Overview

Fabrikam Lettings Ltd's Microsoft 365 tenant was reviewed on 19/10/2026 against 131 checks across 15 areas. The weighted score is 44% (Red). Of the checks assessed, 20 failed, 77 need attention and 15 passed. 16 high-severity issues should be addressed first. Estimated remediation effort for all failed and warning items is about 357.0 hours (47.6 days).

The tenant already has licences for features that are not being used. Not used: 7. Partly used: 11. Setting these up is estimated at 36.5 days (see Opportunities).

Against the published benchmarks the tenant meets: CIS v7.0.0 22% (29 of 130 assessed controls, 15 to check manually); CISA SCuBA 26% (24 of 92 assessed controls, 6 to check manually) (see Benchmarks).

Azure was reviewed separately (2 subscriptions): the Azure score is 26%, with 9 failed and 18 needing attention (see Azure).

Servers were reviewed separately (6 systems from collected server data): the server score is 10%, with 21 failed and 7 needing attention (see Servers).

What needs doing

Must do
40 items
Start within 2 weeks
About 18 days

Should do
16 items
Within 3 months
About 5 days

Could do
96 items
Within 6 months
About 25 days

Use what you already pay for
18 features
After the fixes above
About 36.5 days

40 must-do items should be started within two weeks (about 18 days), 16 should-do items within three months (about 5 days) and 96 could-do items within six months (about 25 days). In total this is about 48 days of engineer time, or roughly 25 weeks at 2 engineer days a week. 12 of the must-do and should-do items are quick wins of an hour or less. A further 18 licensed features you already pay for could be put to use (about 36.5 days). See the action plan.

Top priorities

When	What good looks like	What we found	Effort
Must do	Windows servers run a supported version	1 of 5 Windows servers is out of support; 1 more loses support within six months.	2.5 days
Must do	Active Directory replication and SYSVOL are healthy	2 replication or SYSVOL problems found.	4 hours
Must do	Microsoft Defender for Cloud protects servers and data services	3 Defender plans are not on for resources in use, including Defender for Servers in 1 subscription. The plans in Fabrikam Dev could not be read (the account needs Security Reader or Reader there).	3 hours
Must do	Licensed users are registered for MFA	88% of 25 enabled licensed users are MFA capable (3 not capable).	4 hours
Must do	SPF records are valid	Mail domains with SPF problems: 1 of 2.	1 hour
Must do	Compliance policies cover every enrolled platform	No assigned compliance policy for: Android	4 hours
Must do	Devices are onboarded to Defender for Endpoint	Onboarded devices: 4. Intune managed Windows and macOS devices: 4 of 6 onboarded (66.7%).	4 hours

When	What good looks like	What we found	Effort
Must do	Linux servers run a supported release and are patched	The only Linux server is out of support or missing security updates.	1.5 days
Must do	No retired Basic SKU public IPs or load balancers	1 public IP address still uses the retired Basic SKU.	4 hours
Must do	No guest accounts hold admin roles	Admin role assignments held by guests: 1.	30 minutes

Results by area

Area	RAG	Fail	Warning	Pass	Info or manual
Active Directory	Red	6	2	0	0
Applications	Amber	0	3	1	1
Autopilot and enrolment	Amber	0	2	0	0
Azure governance and cost	Red	1	7	0	1
Azure resilience	Red	2	3	0	0
Azure security	Red	6	8	0	1
Compliance	Amber	0	2	1	0
Email authentication	Red	3	1	1	1
Exchange Online	Red	2	11	6	1
Governance	Not rated	0	0	0	1
Hyper-V	Amber	1	1	0	0
Identity and access	Red	4	16	3	2
Intune and devices	Red	3	7	1	1
Intune configuration health	Amber	0	4	0	0
Intune connections	Red	1	2	1	0
Licensing	Amber	0	4	0	1
Linux servers	Red	3	1	0	0
Microsoft Defender XDR	Red	3	5	0	1
Microsoft Purview	Amber	0	4	0	1

Area	RAG	Fail	Warning	Pass	Info or manual
Microsoft Secure Score	Amber	1	0	0	0
Permissions	Amber	0	1	0	1
Privileged access	Red	2	3	0	1
SharePoint and OneDrive	Amber	0	5	1	3
Teams and groups	Amber	0	1	0	4
VMware	Not rated	0	0	0	2
Windows security configuration	Amber	1	6	0	0
Windows servers	Red	11	3	0	1

Licensed but not used

Status	Feature	Licensed users	Current use
Not used	Self-service password reset	24	Enabled for SSPR: 0 of 24 licensed users; registered: 21.
Not used	Dynamic groups	24	Dynamic membership groups: 0.
Not used	Universal Print	24	Printers registered in Universal Print: 0.
Not used	Sensitivity labels	24	Sensitivity labels: 0; active label policies: 0.
Not used	Online archiving	24	User mailboxes with an active archive: 0 of 22; mailboxes over 40 GB without an archive: 1.
Not used	Device-based Conditional Access	22	Enabled policies requiring a compliant or joined device: 0 (0 for all users).
Not used	Teams Phone	2	Users licensed for Teams Phone: 2; numbers assigned to users: 0; other assigned numbers: 0.
Partly used	Retention policies	25	Active retention policies: 1; workloads covered org-wide: Exchange.

2. Action plan

This plan turns the findings into work, grouped by what it protects and ordered by urgency. Must do items are serious gaps to fix first, should do items are important improvements, and could do items are good practice. Effort is the estimated engineer time to make each change; it is for planning only and does not include time for agreeing changes, telling staff or testing with Fabrikam Lettings Ltd.

Must do
40 items
Start within 2 weeks
About 18 days

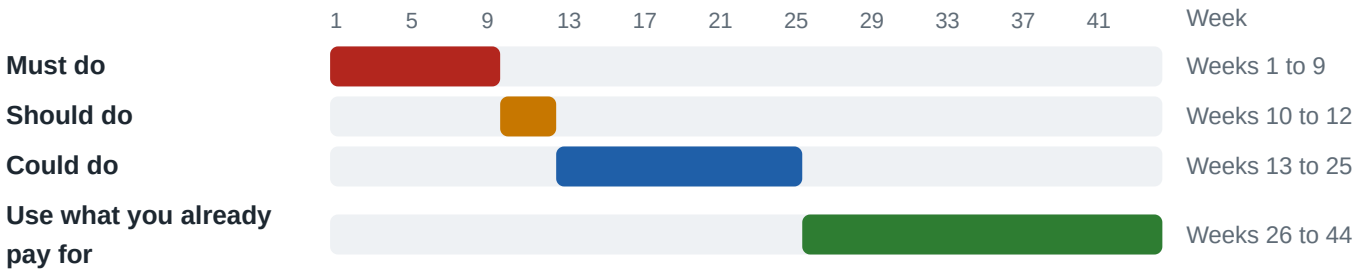
Should do
16 items
Within 3 months
About 5 days

Could do
96 items
Within 6 months
About 25 days

Use what you already pay for
18 features
After the fixes above
About 36.5 days

40 must-do items should be started within two weeks (about 18 days), 16 should-do items within three months (about 5 days) and 96 could-do items within six months (about 25 days). In total this is about 48 days of engineer time, or roughly 25 weeks at 2 engineer days a week. 12 of the must-do and should-do items are quick wins of an hour or less. A further 18 licensed features you already pay for could be put to use (about 36.5 days).

Indicative timeline



Based on 2 engineer days a week. With more engineer time the phases can overlap and finish sooner. Some licensed features overlap with the fixes, so that work may take less time once the earlier phases are done.

1 Must do: start within 2 weeks

Serious gaps that leave the business open to attack, data loss or disruption today. These should be fixed first.

Patch, protect and back up servers

About 5.5 days

Why it matters. Servers hold your most important data and systems. Servers that are out of support, unpatched, unprotected or not backed up are the most common way ransomware gets in and causes lasting damage.

Windows servers run a supported version — 2.5 days
We found: 1 of 5 Windows servers is out of support; 1 more loses support within six months.

Windows servers are patched and rebooted — 4 hours
We found: 1 of 5 servers is missing security updates.

Windows servers have working EDR and antivirus — 2 hours
We found: 1 of 5 servers has no EDR.

Remote management is not exposed or weakly protected — 2 hours
We found: 1 of 5 servers allows weakly protected remote access.

SMBv1 is disabled and SMB signing is required — 2 hours

We found: SMBv1 is enabled on 1 server; signing is not required on 2 servers.

Local administrator accounts are managed — 3 hours

We found: 1 of 3 member servers has unmanaged local administrator accounts.

Servers are backed up — 2 hours

We found: 1 server has not completed a Windows Server Backup in the last two days.

No out-of-support server software — 1.5 days

We found: 4 items of out-of-support software were found.

WHAT YOUR STAFF WILL NOTICE

Servers may need short, planned restarts outside working hours.

WHAT WE NEED FROM YOU

Agree a maintenance window, and budget for replacing any servers that are out of support.

Secure Active Directory

About 2.5 days

Why it matters. Active Directory controls sign-in to every PC and server. A weakness here can let one compromised account take over the whole network.

Active Directory replication and SYSVOL are healthy — 4 hours

We found: 2 replication or SYSVOL problems found.

Privileged AD groups are small and protected — 3 hours

We found: Domain Admins is too large (7 members; two to four is recommended).

No accounts open to Kerberos and delegation attacks — 4 hours

We found: 2 high-risk account settings found (3 more to review).

Domain password and lockout policy is strong — 2 hours

We found: The domain password or lockout policy is weak: minimum length 8, no account lockout, history 12.

Domain controllers are hardened — 3 hours

We found: Both domain controllers need hardening.

WHAT YOUR STAFF WILL NOTICE

Mostly no change. A few old accounts may be disabled and some service accounts given new passwords.

WHAT WE NEED FROM YOU

Confirm which old accounts and service accounts are still needed.

Secure your Azure services

About 2.5 days

Why it matters. Cloud servers and services that are open to the internet, or have no security monitoring, are a frequent target for attackers.

Microsoft Defender for Cloud protects servers and data services — 3 hours

We found: 3 Defender plans are not on for resources in use, including Defender for Servers in 1 subscription. The plans in Fabrikam Dev could not be read (the account needs Security Reader or Reader there).

Management ports are not open to the internet — 2 hours

We found: 1 rule in use allows management or database ports from the internet.

Servers run a supported operating system — 1.5 days

We found: 3 servers are out of support. 1 more server is on extended security updates or loses support within six months.

Azure servers are onboarded to Defender for Endpoint — 3 hours

We found: 2 of 3 running servers are not onboarded to Defender for Endpoint.

Storage accounts block public access and require TLS 1.2 — 2 hours

We found: 1 of 2 storage accounts allows anonymous access, HTTP or old TLS.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm which Azure services must be reachable from the internet.

Protect sign-ins and accounts

About 1.5 days

Why it matters. Most attacks start with a stolen or guessed password. These changes make it much harder for anyone to get into a staff account, even if they have the password.

Licensed users are registered for MFA — 4 hours
We found: 88% of 25 enabled licensed users are MFA capable (3 not capable).

All administrators are registered for MFA — 1 hour
We found: Admin accounts not MFA capable: 1 of 7.

Users cannot consent to applications — 1 hour
We found: Users can consent to any application for any delegated permission.

Directory synchronisation is healthy — 2 hours
We found: Last sync 18/10/2026 03:50 (30 hours ago).

WHAT YOUR STAFF WILL NOTICE

Staff may be asked to set up an authenticator app and could be prompted to sign in again on their devices.

WHAT WE NEED FROM YOU

Agree a date to tell staff, and confirm any shared or emergency accounts that need different treatment.

Stop others sending email as you

About 3 hours

Why it matters. SPF, DKIM and DMARC records prove your email is genuine. Without them, criminals can send convincing emails that look as if they come from you, to your staff, customers and suppliers.

SPF records are valid — 1 hour
We found: Mail domains with SPF problems: 1 of 2.

DKIM signing is enabled for every mail domain — 1 hour
We found: Email domains not DKIM signing: 1 of 2.

DMARC is published and enforced — 1 hour
We found: Domains without DMARC: 2; not enforcing: 1.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Access to your DNS provider, and a list of other services that send email for you (for example invoicing or marketing systems).

Secure laptops, desktops and phones

About 2 days

Why it matters. Devices hold company data and are used to sign in. Managing, encrypting and updating them protects that data if a device is lost, stolen or infected.

Compliance policies cover every enrolled platform — 4 hours
We found: No assigned compliance policy for: Android

Windows devices are encrypted — 4 hours
We found: Windows devices reporting as not encrypted: 2 of 6.

Windows devices run a supported version — 4 hours
We found: Windows devices: 6; on Windows 10: 1; on Windows 11 below the minimum build: 1.

WHAT YOUR STAFF WILL NOTICE

Devices may restart for updates, and staff may be asked to enrol phones or accept new settings.

WHAT WE NEED FROM YOU

Agree a small pilot group first, then a date for everyone else.

Detect and respond to threats

About 2 days

Why it matters. Security tools only help if they are switched on, cover every device and someone acts on their alerts.

Devices are onboarded to Defender for Endpoint — 4 hours
We found: Onboarded devices: 4. Intune managed Windows and macOS devices: 4 of 6 onboarded (66.7%).

No critical vulnerabilities with public exploits 1.5 days

We found: Software with critical vulnerabilities: 2 (2 with public exploits). Software with high or critical vulnerabilities: 3.

Security incidents are triaged and resolved 2 hours

We found: Incidents in the last 90 days: 2. Open: 1 (1 high severity). High-severity incidents open for more than 7 days: 1.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm who should receive security alerts, including out of hours.

Patch and harden Linux servers

About 2 days

Why it matters. Linux servers often run websites, databases and file transfers that face the internet. Keeping them patched and locked down stops them becoming a way in.

Linux servers run a supported release and are patched 1.5 days

We found: The only Linux server is out of support or missing security updates.

Linux SSH and accounts are hardened 2 hours

We found: The only Linux server allows risky SSH or account access.

Linux servers have EDR, a firewall and audit logging 3 hours

We found: The only Linux server has no EDR.

WHAT YOUR STAFF WILL NOTICE

Servers may need short, planned restarts outside working hours.

WHAT WE NEED FROM YOU

Agree a maintenance window and who owns each server.

Make sure Azure can recover

About 7 hours

Why it matters. Backups and protection against accidental deletion mean a mistake or a ransomware attack does not become a lasting outage.

No retired Basic SKU public IPs or load balancers 4 hours

We found: 1 public IP address still uses the retired Basic SKU.

Virtual machines are backed up 3 hours

We found: 2 of 4 virtual machines are not protected by Azure Backup, and 1 more has not backed up recently.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm how much data you could afford to lose and how quickly systems must be back.

Lock down administrator access

About 30 minutes

Why it matters. Administrator accounts can change or delete anything. Keeping them few in number and well protected limits the damage if one is compromised.

No guest accounts hold admin roles 30 minutes

We found: Admin role assignments held by guests: 1.

WHAT YOUR STAFF WILL NOTICE

Only IT administrators are affected.

WHAT WE NEED FROM YOU

Confirm who genuinely needs administrator access.

Strengthen email security

About 1 hour

Why it matters. Email is the most common way criminals reach staff, through phishing and harmful attachments. These settings block more threats and stop email being quietly forwarded outside the business.

Mailbox forwarding is reviewed 1 hour

We found: Mailboxes forwarding mail: 1 (1 to external addresses).

WHAT YOUR STAFF WILL NOTICE

Little change for staff. Some suspicious messages will be held in quarantine instead of reaching inboxes.

WHAT WE NEED FROM YOU

Tell us about any automatic forwarding to outside addresses that the business relies on.

Keep device management working

About 1 hour

Why it matters. Device management relies on certificates and connections to Apple and Google. If these lapse, company phones and tablets can no longer be managed or wiped, and fixing it can mean re-enrolling every device.

Apple MDM push certificate is valid — 1 hour

We found: The Apple MDM push certificate expires in 20 days (08/11/2026). Renew it with Apple ID it.fabrikam@personal.example.

WHAT YOUR STAFF WILL NOTICE

No change for staff if this is done before the expiry date.

WHAT WE NEED FROM YOU

Access to the Apple or Google account that was used to set these up.

Control Azure access and cost

About 2 hours

Why it matters. Clear ownership, budgets and removing unused resources stop surprise bills and limit who can change live systems.

Subscription owners are limited and not guests — 2 hours

We found: 4 privileged role assignments at subscription or management group level (2 to users directly, 1 to service principals, 1 to guests).

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Agree a monthly Azure budget and who should be alerted.

2 Should do: within 3 months

Important improvements that close real risks. Plan these into the next three months.

Secure laptops, desktops and phones

About 1.5 days

Why it matters. Devices hold company data and are used to sign in. Managing, encrypting and updating them protects that data if a device is lost, stolen or infected.

Windows LAPS policy manages local administrator passwords — 2 hours

We found: Assigned LAPS policy: Windows LAPS. Passwords are backed up to Microsoft Entra ID, rotated every 90 days.

BitLocker policy requires encryption and escrows recovery keys — 3 hours

We found: BitLocker encryption is required (policy: BitLocker), but no assigned policy makes devices save recovery keys to Entra ID before encrypting.

Attack surface reduction rules are in block mode — 4 hours

We found: 7 rules configured: 4 in block mode, 3 in audit, warn or off. 2 of the three standard protection rules are not blocked.

Windows Firewall is enforced on every profile — 2 hours

We found: No assigned policy turns on Windows Firewall.

WHAT YOUR STAFF WILL NOTICE

Devices may restart for updates, and staff may be asked to enrol phones or accept new settings.

WHAT WE NEED FROM YOU

Agree a small pilot group first, then a date for everyone else.

Protect sign-ins and accounts

About 2 hours

Why it matters. Most attacks start with a stolen or guessed password. These changes make it much harder for anyone to get into a staff account, even if they have the password.

Legacy authentication is blocked — 2 hours

We found: Legacy authentication block is in report-only mode: CA002 Block legacy authentication

WHAT YOUR STAFF WILL NOTICE

Staff may be asked to set up an authenticator app and could be prompted to sign in again on their devices.

WHAT WE NEED FROM YOU

Agree a date to tell staff, and confirm any shared or emergency accounts that need different treatment.

Control connected apps

About 3 hours

Why it matters. Apps connected to your accounts can often read email and files. Reviewing them, and requiring approval for new ones, stops data being handed to unsafe apps without anyone noticing.

High-risk application permissions are reviewed — 3 hours

We found: Applications with high-risk application permissions: 2.

WHAT YOUR STAFF WILL NOTICE

Staff will need approval before connecting new apps to their work account.

WHAT WE NEED FROM YOU

Confirm which connected apps are used for business.

Secure Active Directory

About 5 hours

Why it matters. Active Directory controls sign-in to every PC and server. A weakness here can let one compromised account take over the whole network.

LAPS covers domain computers — 3 hours

We found: LAPS covers 53.4% of computers in the weakest domain.

Directory recovery and krbtgt hygiene — 2 hours

We found: fabrikam.local: AD Recycle Bin off; krbtgt password 1462 days old; machine account quota 10; domain functional level Windows2012R2Domain.

WHAT YOUR STAFF WILL NOTICE

Mostly no change. A few old accounts may be disabled and some service accounts given new passwords.

WHAT WE NEED FROM YOU

Confirm which old accounts and service accounts are still needed.

Lock down administrator access

About 1 hour

Why it matters. Administrator accounts can change or delete anything. Keeping them few in number and well protected limits the damage if one is compromised.

Between two and four Global Administrators — 1 hour

We found: Global Administrators: 5.

WHAT YOUR STAFF WILL NOTICE

Only IT administrators are affected.

WHAT WE NEED FROM YOU

Confirm who genuinely needs administrator access.

Strengthen email security

About 2 hours

Why it matters. Email is the most common way criminals reach staff, through phishing and harmful attachments. These settings block more threats and stop email being quietly forwarded outside the business.

SMTP AUTH client submission is disabled — 2 hours

We found: SMTP AUTH is enabled for the whole organisation.

WHAT YOUR STAFF WILL NOTICE

Little change for staff. Some suspicious messages will be held in quarantine instead of reaching inboxes.

WHAT WE NEED FROM YOU

Tell us about any automatic forwarding to outside addresses that the business relies on.

Detect and respond to threats

About Minimal

Why it matters. Security tools only help if they are switched on, cover every device and someone acts on their alerts.

Microsoft Secure Score — Minimal

We found: Secure Score 312 of 640 (48.8%). Comparable organisations (TotalSeats) average 44.6.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm who should receive security alerts, including out of hours.

Patch, protect and back up servers

About 1.5 days

Why it matters. Servers hold your most important data and systems. Servers that are out of support, unpatched, unprotected or not backed up are the most common way ransomware gets in and causes lasting damage.

Windows servers meet the hardening baseline — 6 hours

We found: 49.7% of baseline settings are met across 5 servers. 3 servers are below 60%.

Server volumes have free space — 1 hour

We found: 1 volume is under 10% free.

Server time, certificates and stability — 1 hour

We found: 2 of 5 servers have time, certificate or stability issues.

WHAT YOUR STAFF WILL NOTICE

Servers may need short, planned restarts outside working hours.

WHAT WE NEED FROM YOU

Agree a maintenance window, and budget for replacing any servers that are out of support.

Keep virtualisation hosts healthy

About 2 hours

Why it matters. One host runs many servers, so a problem there affects all of them. Old snapshots, unsupported versions and missing redundancy put every virtual server at risk.

Hyper-V virtual machines are healthy — 2 hours

We found: 2 virtual machines have old checkpoints, replication or cluster problems.

WHAT YOUR STAFF WILL NOTICE

Hosts may need planned maintenance windows.

WHAT WE NEED FROM YOU

Agree maintenance windows and any budget for host upgrades.

Secure your Azure services

About 1 hour

Why it matters. Cloud servers and services that are open to the internet, or have no security monitoring, are a frequent target for attackers.

App Service apps enforce HTTPS and TLS 1.2 — 1 hour

We found: 1 of 1 apps allows HTTP, old TLS or plain FTP.

WHAT YOUR STAFF WILL NOTICE

No change for staff.

WHAT WE NEED FROM YOU

Confirm which Azure services must be reachable from the internet.

3 Could do: within 6 months

Good-practice improvements that tighten security further and bring you in line with the published benchmarks. Select an item to see what we found.

Protect sign-ins and accounts

About 3 days

Why it matters. Most attacks start with a stolen or guessed password. These changes make it much harder for anyone to get into a staff account, even if they have the password.

Administrators use phishing-resistant MFA — 3 hours

Weak MFA methods (SMS and voice) are disabled — 2 hours

Conditional Access requires compliant or managed devices — 4 hours

Users cannot register applications or create tenants	30 minutes
Guest invitations are restricted	30 minutes
Guest user access to the directory is restricted	30 minutes
No inactive enabled user accounts	3 hours
Windows LAPS is enabled	2 hours
Strong authentication methods are enabled	1 hour
Report-only and disabled Conditional Access policies	1 hour
Admin consent workflow is enabled	1 hour
Self-service sign-up is disabled	30 minutes
Passwords are set not to expire	30 minutes
No inactive guest accounts	1 hour
No stale devices in Entra ID	2 hours

WHAT YOUR STAFF WILL NOTICE
Staff may be asked to set up an authenticator app and could be prompted to sign in again on their devices.

WHAT WE NEED FROM YOU
Agree a date to tell staff, and confirm any shared or emergency accounts that need different treatment.

Lock down administrator access

About 6 hours

Why it matters. Administrator accounts can change or delete anything. Keeping them few in number and well protected limits the damage if one is compromised.

Privileged accounts are cloud-only	2 hours
Service principals with privileged directory roles	1 hour
Admins use separate accounts from daily email accounts	3 hours

WHAT YOUR STAFF WILL NOTICE
Only IT administrators are affected.

WHAT WE NEED FROM YOU
Confirm who genuinely needs administrator access.

Strengthen email security

About 2 days

Why it matters. Email is the most common way criminals reach staff, through phishing and harmful attachments. These settings block more threats and stop email being quietly forwarded outside the business.

Mail flow rules do not weaken security	2 hours
Anti-spam policies do not allow whole sender domains	1 hour
Anti-phishing protection is configured	2 hours
Safe Links protects email, Teams and Office apps	2 hours
Safe Attachments is enabled	1 hour
Sign-in is blocked for shared and resource mailboxes	1 hour
External sender tagging is enabled in Outlook	30 minutes
Calendar details are not shared anonymously	30 minutes
Outlook on the web third-party storage is disabled	30 minutes
POP and IMAP are disabled where not needed	1 hour
Mailboxes approaching their quota	1 hour

WHAT YOUR STAFF WILL NOTICE
Little change for staff. Some suspicious messages will be held in quarantine instead of reaching inboxes.

WHAT WE NEED FROM YOU
Tell us about any automatic forwarding to outside addresses that the business relies on.

Stop others sending email as you

About 1 hour

Why it matters. SPF, DKIM and DMARC records prove your email is genuine. Without them, criminals can send convincing emails that look as if they come from you, to your staff, customers and suppliers.

Domains that do not send mail are locked down	1 hour

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Access to your DNS provider, and a list of other services that send email for you (for example invoicing or marketing systems).

Secure laptops, desktops and phones

About 5 days

Why it matters. Devices hold company data and are used to sign in. Managing, encrypting and updating them protects that data if a device is lost, stolen or infected.

Devices without a compliance policy are marked non-compliant	30 minutes
Managed devices are compliant	3 hours
Endpoint security policies are deployed	6 hours
App protection policies protect mobile data	3 hours
Policies apply without errors or conflicts	3 hours
Microsoft Defender Antivirus protections are on	2 hours
Windows Hello for Business is configured	3 hours
Security baselines are deployed and current	6 hours
Autopilot profiles are assigned and users are not local administrators	2 hours
Enrolment Status Page holds users until setup completes	2 hours
Required apps install successfully	3 hours
Devices are checking in with Intune	1 hour
Personal Windows device enrolment is blocked	1 hour
Intune policies are assigned	1 hour
Device clean-up rule removes inactive devices	30 minutes
Windows update management	Minimal

WHAT YOUR STAFF WILL NOTICE
Devices may restart for updates, and staff may be asked to enrol phones or accept new settings.

WHAT WE NEED FROM YOU
Agree a small pilot group first, then a date for everyone else.

Keep device management working

About 3 hours

Why it matters. Device management relies on certificates and connections to Apple and Google. If these lapse, company phones and tablets can no longer be managed or wiped, and fixing it can mean re-enrolling every device.

Apple Apps and Books (VPP) tokens are valid	1 hour
Android Enterprise is connected	2 hours

WHAT YOUR STAFF WILL NOTICE
No change for staff if this is done before the expiry date.

WHAT WE NEED FROM YOU
Access to the Apple or Google account that was used to set these up.

Detect and respond to threats

About 2 days

Why it matters. Security tools only help if they are switched on, cover every device and someone acts on their alerts.

Discovered devices that can be onboarded	2 hours
Onboarded devices report a healthy sensor	2 hours
High-impact secure configuration gaps are addressed	6 hours
No devices with a high exposure level	2 hours
Defender for Endpoint is connected to Intune	1 hour

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Confirm who should receive security alerts, including out of hours.

Control file sharing

About 4.5 hours

Why it matters. Files shared with open links can be passed on to anyone. Tightening sharing reduces the chance of sensitive documents reaching the wrong people.

Anonymous (Anyone) sharing links are controlled	2 hours
Guests cannot reshare content they do not own	30 minutes
Guests must sign in with the invited account	30 minutes
Legacy authentication is blocked for SharePoint	30 minutes
Idle session sign-out is configured	1 hour

WHAT YOUR STAFF WILL NOTICE
Staff may need to share with named people rather than with anyone who has the link.

WHAT WE NEED FROM YOU
Agree how staff should share files with clients and suppliers.

Secure meetings, chat and groups

About 2 hours

Why it matters. Settings for who can join meetings, message your staff and create groups decide how easily outsiders get in and how easily information leaks out.

Every group and Team has an owner	2 hours

WHAT YOUR STAFF WILL NOTICE
External guests may wait in a lobby or need an invitation to join.

WHAT WE NEED FROM YOU
Confirm which outside organisations staff need to work with.

Control connected apps

About 3 hours

Why it matters. Apps connected to your accounts can often read email and files. Reviewing them, and requiring approval for new ones, stops data being handed to unsafe apps without anyone noticing.

User-consented applications are reviewed	2 hours
App registration credentials are current	1 hour

WHAT YOUR STAFF WILL NOTICE
Staff will need approval before connecting new apps to their work account.

WHAT WE NEED FROM YOU
Confirm which connected apps are used for business.

Protect and keep important information

About 3 days

Why it matters. Backup, retention, audit logging and data loss prevention help you meet obligations such as UK GDPR, recover deleted information and investigate problems.

Windows compliance policy checks the essentials	2 hours
Mobile compliance policies require a passcode and block jailbroken devices	2 hours
Data loss prevention policies protect sensitive data	6 hours
Retention policies cover email, files and Teams	3 hours
Sensitivity labels are defined and published	1.5 days
Default alert policies are enabled and notify administrators	1 hour

WHAT YOUR STAFF WILL NOTICE
Staff may see a tip before sharing sensitive information outside the business.

WHAT WE NEED FROM YOU
Confirm how long different types of information must be kept.

Tidy up who can see what

About 1 hour

Why it matters. Over time people collect access to mailboxes, sites and groups they no longer need. Removing it limits what a leaver or an attacker could see.

Mailbox permissions do not reference deleted or disabled accounts	1 hour

WHAT YOUR STAFF WILL NOTICE
Some staff will lose access to mailboxes or sites they no longer use.

WHAT WE NEED FROM YOU
Confirm who should keep access.

Make sure licences are right

About 2.5 hours

Why it matters. Unused or unsuitable licences cost money every month and can leave security features out of reach.

Subscriptions are in good standing	30 minutes
Unassigned paid licences	30 minutes
No licences assigned to disabled accounts	1 hour
Shared and resource mailboxes are not licensed unnecessarily	30 minutes

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Approve any licence changes.

Patch, protect and back up servers

About 6 hours

Why it matters. Servers hold your most important data and systems. Servers that are out of support, unpatched, unprotected or not backed up are the most common way ransomware gets in and causes lasting damage.

Security logging and audit policy are in place	2 hours
Unnecessary and risky services are not running	2 hours
Physical servers encrypt their disks	2 hours

WHAT YOUR STAFF WILL NOTICE
Servers may need short, planned restarts outside working hours.

WHAT WE NEED FROM YOU
Agree a maintenance window, and budget for replacing any servers that are out of support.

Secure Active Directory

About 3 hours

Why it matters. Active Directory controls sign-in to every PC and server. A weakness here can let one compromised account take over the whole network.

Stale and out-of-support accounts are cleaned up	3 hours

WHAT YOUR STAFF WILL NOTICE
Mostly no change. A few old accounts may be disabled and some service accounts given new passwords.

WHAT WE NEED FROM YOU
Confirm which old accounts and service accounts are still needed.

Keep virtualisation hosts healthy

About 1.5 days

Why it matters. One host runs many servers, so a problem there affects all of them. Old snapshots, unsupported versions and missing redundancy put every virtual server at risk.

Hyper-V hosts are dedicated	1.5 days

WHAT YOUR STAFF WILL NOTICE
Hosts may need planned maintenance windows.

WHAT WE NEED FROM YOU
Agree maintenance windows and any budget for host upgrades.

Patch and harden Linux servers

About 1 hour

Why it matters. Linux servers often run websites, databases and file transfers that face the internet. Keeping them patched and locked down stops them becoming a way in.

Linux disk space, packages and kernel settings	1 hour

WHAT YOUR STAFF WILL NOTICE
Servers may need short, planned restarts outside working hours.

WHAT WE NEED FROM YOU
Agree a maintenance window and who owns each server.

Secure your Azure services

About 4 days

Why it matters. Cloud servers and services that are open to the internet, or have no security monitoring, are a frequent target for attackers.

Defender for Cloud secure score	1.5 days
Microsoft cloud security benchmark compliance	1.5 days
Virtual machines do not have public IP addresses	2 hours
Subnets are protected by network security groups	2 hours
Key vaults have purge protection and restricted network access	1 hour
Servers have no outstanding critical or security updates	3 hours
Defender for Cloud alert emails reach the right people	30 minutes
Virtual machines use Trusted Launch	2 hours

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Confirm which Azure services must be reachable from the internet.

Make sure Azure can recover

About 6 hours

Why it matters. Backups and protection against accidental deletion mean a mistake or a ransomware attack does not become a lasting outage.

Backup vaults are protected against deletion and ransomware	1 hour
High-impact Azure Advisor recommendations	4 hours
Azure Arc servers are connected	1 hour

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Confirm how much data you could afford to lose and how quickly systems must be back.

Control Azure access and cost

About 7 hours

Why it matters. Clear ownership, budgets and removing unused resources stop surprise bills and limit who can change live systems.

The Azure activity log is kept beyond 90 days	1 hour
Critical resources have delete locks	1 hour
No unattached disks or unused public IP addresses	1 hour
Azure Advisor cost recommendations	2 hours
Every subscription has a budget alert	30 minutes
The Microsoft cloud security benchmark policy is assigned	1 hour
Network Watcher is enabled where networks exist	30 minutes

WHAT YOUR STAFF WILL NOTICE
No change for staff.

WHAT WE NEED FROM YOU
Agree a monthly Azure budget and who should be alerted.

4 Use what you already pay for

Features included in your current licences that are not set up yet. Using them adds protection or saves time at no extra licence cost.

Feature	Now	What it gives you	Effort
Self-service password reset	Not used	Fewer password reset calls to the service desk and faster recovery for users out of hours.	0.5 days
Dynamic groups	Not used	Less manual administration and fewer access mistakes when staff change roles.	0.5 days
Universal Print	Not used	Cloud printing from Entra joined devices with no print server to patch.	1.5 days
Sensitivity labels	Not used	Sensitive documents stay protected wherever they go, and it prepares the tenant for Copilot by controlling what it can surface.	4 days
Online archiving	Not used	Keeps large mailboxes fast and within quota without buying extra storage.	0.5 days
Device-based Conditional Access	Not used	Stolen passwords alone cannot be used to download company data to an unmanaged computer.	1.5 days
Teams Phone	Not used	Replaces a separate phone system and puts calling in the app users already have open.	3 days
Retention policies	Partly used	Protection against accidental or malicious deletion beyond the default recycle bin periods, and support for legal obligations.	1 day
Conditional Access	Partly used	Granular, auditable access control that security defaults cannot provide, without blocking legitimate users.	2 days
Defender for Endpoint or Defender for Business	Partly used	Endpoint detection and response that can stop ransomware, often replacing a separately licensed antivirus product.	3 days
Defender for Office 365 (Safe Links, Safe Attachments, impersonation)	Partly used	Stronger protection against phishing, business email compromise and malicious attachments than the default built-in policy.	1 day

Feature	Now	What it gives you	Effort
Data loss prevention for email and files	Partly used	Reduces the risk of a reportable data breach from misdirected email or oversharing.	3 days
Microsoft 365 desktop apps	Partly used	Users get current, supported Office apps and the client can stop paying for separate Office licences.	1 day
OneDrive	Partly used	User files are backed up to the cloud and a lost laptop no longer means lost work.	1 day
SharePoint for company files	Partly used	Secure access from anywhere, version history and co-authoring, and one less server to maintain and back up.	5 days
Intune device management	Partly used	Consistent, provable device security and remote wipe for lost or stolen devices.	5 days
App protection for mobiles	Partly used	Supports bring-your-own phones while keeping company data contained.	1 day
Microsoft 365 Copilot	Partly used	A return on an expensive licence, and idle licences moved to people who will use them.	2 days

Things to confirm with you

These could not be checked automatically. We will go through them with you.

Teams external access and anonymous meeting join

Teams policy settings are not readable through delegated Graph access. Check in the Teams admin centre.

Microsoft 365 data is backed up

Backup coverage cannot be read from the tenant. Confirm the backup product, scope and last successful run.